

CEH v13 PRACTICE GUIDE

Knowledge Exam · 312-50

Exam-focused revision · Modules 01–20

Built from your notes + Gaps & Corrections + All-in-One Exam Guide

Contents

How to Use This Guide	3
Module 01 — Introduction to Ethical Hacking	3
Module 02 — Footprinting & Reconnaissance	4
Module 03 — Scanning Networks	5
Module 04 — Enumeration	5
Module 05 — Vulnerability Analysis	6
Module 06 — System Hacking	7
Module 07 — Malware Threats	7
Module 08 — Sniffing	8
Module 09 — Social Engineering	9
Module 10 — Denial-of-Service	9
Module 11 — Session Hijacking	10
Module 12 — Evading IDS, Firewalls & Honeypots	11
Module 13 — Hacking Web Servers	11
Module 14 — Hacking Web Applications	12
Module 15 — SQL Injection	13
Module 16 — Hacking Wireless Networks	13
Module 17 — Hacking Mobile Platforms	14
Module 18 — IoT and OT Hacking	14
Module 19 — Cloud Computing	15
Module 20 — Cryptography	16
Scoring Benchmark & Self-Review	16
21-Day CEH Practice Plan	17
Final 72 Hours Before CEH	18
Last-Minute Rapid Review (30-45 min)	18

How to Use This Guide

This is an **exam-focused revision and practice guide** for the CEH v13 Knowledge Exam (**312-50**), not a textbook. It is built from your notes, the Gaps & Corrections layer, and the All-in-One Exam Guide, framed in CEH v13 terminology.

Exam facts to anchor on: 125 questions · multiple choice · single best answer · 4 hours · exam code **312-50**.

Each module below gives you eight things: A. High-Yield Concepts — B. Must-Know Definitions — C. Commonly Confused Concepts — D. Tool Recognition — E. Attack → Target → Effect → Defense — F. Methodology / Sequence — G. High-Value Facts — H. Exam Traps (what you are likely to confuse).

Source labels used: [OFFICIAL] CEH v13 courseware framing · [EXAM GUIDE] All-in-One supported · [SUPP] supplementary external knowledge (not EC-Council).

Study benchmark (NOT the official EC-Council cut score): target **106/125 ≈ 85%**.

Module 01 — Introduction to Ethical Hacking

A. High-Yield Concepts

- **CIA triad + Authenticity and Non-Repudiation.**
- **Security-Functionality-Ease-of-Use triangle:** as security rises, functionality/usability fall.
- **Hacking phases:** Reconnaissance → Scanning → Gaining Access → Maintaining Access → Clearing Tracks.
- **Cyber Kill Chain** (7) and **MITRE ATT&CK** (Tactics→Techniques→Procedures = TTPs).
- **Attack classifications:** Passive, Active, Close-in, Insider, Distribution.
- Ethical hacking requires **scope + written authorization** (Rules of Engagement). ## B. Must-Know Definitions
- **Threat:** a potential danger/event. **Vulnerability:** a weakness. **Risk:** likelihood × impact of a threat exploiting a vulnerability.
- **Exploit:** method/code that leverages a vulnerability. **Zero-day:** vuln with no available patch.
- **Daisy-chaining:** using one compromised host to reach another. **Shrink-wrap attack:** exploiting default code/config in off-the-shelf software.
- **Hack value:** attacker's perceived worth of a target. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Threat | Vulnerability | Danger vs weakness that enables it | | Vulnerability | Risk | Weakness vs expected loss (likelihood×impact) | | Authentication | Authorization | Who you are vs what you may do | | Confidentiality | Authenticity | Prevent disclosure vs verify genuine source | | Black / White / Gray box | — | No / full / partial prior knowledge | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | MITRE ATT&CK | Adversary TTP knowledge base | 01 | Threat modeling | | STRIDE | Threat-model categories | 01 | Spoofing/Tampering/... | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Insider misuse | Trusted access | Data loss | Least privilege, monitoring | | Distribution attack | Supply chain | Backdoored product | Vendor vetting, integrity checks | ## F. Methodology / Sequence **CEH phases:** Recon → Scanning → Gaining Access → Maintaining

Access → Clearing Tracks. **Kill Chain:** Recon → Weaponization → Delivery → Exploitation → Installation → C2 → Actions on Objectives. ## G. High-Value Facts

- Security control types: **Preventive, Detective, Corrective, Deterrent, Recovery, Compensating.**
- Control natures: **Physical, Technical/Logical, Administrative.**
- **Diamond Model:** Adversary, Capability, Infrastructure, Victim. ## H. Exam Traps

Watch: Box type (black/white/gray) ≠ hat colour. A white-hat can run a black-box test. "Risk" ≠ "threat" ≠ "vulnerability." IDS is detective, IPS is preventive.

Module 02 — Footprinting & Reconnaissance

A. High-Yield Concepts

- **Passive vs active** footprinting (no interaction vs direct interaction).
- **OSINT** sources; **Google dorking** operators; **WHOIS**; **DNS** records; **DNS zone transfer (AXFR).**
- **Email header** analysis; **nslookup/dig.** ## B. Must-Know Definitions
- **Footprinting:** gathering info about a target to build an attack profile.
- **OSINT:** intelligence from publicly available sources.
- **Zone transfer (AXFR):** copy of an entire DNS zone — big info leak if unrestricted. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Passive footprinting | Active footprinting | No direct contact vs direct interaction | | WHOIS | DNS lookup | Registration/ownership vs name→IP records | | nslookup | dig | Both query DNS; dig = Linux, scriptable | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—| | Google Dorks / GHDB | Advanced search exposure | 02 | site: filetype: inurl: | | WHOIS | Domain registration data | 02 | Registrant/registrar | | nslookup / dig | DNS record queries | 02 | AXFR, MX, NS | | Shodan | Internet-connected devices | 02 | Exposed services | | theHarvester / Maltego / Recon-ng | OSINT collection | 02 | Emails, relationships | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | DNS zone transfer | DNS server | Dump all records | Restrict AXFR to secondaries | | Metadata harvest | Public documents | Usernames/software leak | Metadata scrubbing | ## F. Methodology / Sequence Footprinting through: search engines → web services → social networking → WHOIS → DNS → network → email → social engineering. ## G. High-Value Facts
- DNS records: **A**(IPv4), **AAAA**(IPv6), **MX**(mail), **NS**(name server), **CNAME**(alias), **PTR**(reverse), **SOA**(zone authority), **TXT**(SPF/verification).
- Email security: **SPF** (authorized senders), **DKIM** (integrity/authenticity), **DMARC** (policy).
- **ICMP Type 3 / Code 13** = communication administratively prohibited → firewall filtering. ## H. Exam Traps

Watch: WHOIS privacy hides ownership details, NOT the domain. DNSSEC gives authentication+integrity, NOT encryption. DKIM ≠ confidentiality (it's integrity/authenticity).

Module 03 — Scanning Networks

A. High-Yield Concepts

- Host discovery vs port scanning vs service/OS detection.
- Scan types and their responses; **Nmap** options; firewall/IDS evasion. ## B. Must-Know Definitions
- **SYN (half-open) scan (-ss)**: SYN→SYN/ACK(open)→RST; stealthy, needs root.
- **TCP connect (-sT)**: full handshake; no root; easily logged.
- **ACK scan (-sA)**: maps firewall filtering (filtered vs unfiltered), not open ports. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | -ss SYN | -sT connect | Half-open/stealth vs full handshake | | -sA ACK | -ss SYN | Firewall mapping vs open-port detection | | Open | Filtered | Filtered | No reply (UDP/FIN) vs actively blocked | | -sn | -Pn | Host discovery only vs skip discovery | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Nmap | Scanning/enumeration | 03 | -sS -sU -sV -O -A | | Hping3 | Custom packet crafting | 03 | Firewall testing | | Masscan | Fast port scanning | 03 | Internet-scale | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | SYN scan | Open ports | Map services stealthily | Firewall, IDS, rate limiting | | Decoy scan -D | Attribution | Hide real source | Correlation, logging | ## F. Methodology / Sequence Host discovery → port scanning → service/version detection → OS detection → evasion. ## G. High-Value Facts
- **TCP flags**: SYN, ACK, FIN, RST, PSH, URG.
- **FIN/NULL/XMAS**: no response = **open|filtered**; RST = closed. Works on RFC-793 stacks (Linux), **not Windows** (always RST).
- **UDP scan (-sU)**: ICMP port-unreachable = closed; no reply = open|filtered.
- Default **TTL**: Linux 64, Windows 128, network gear 255 (clue, not proof). ## H. Exam Traps

Watch: ACK scan does NOT find open ports — it maps filtering. “No response” on stealth/UDP scans is open|filtered, not “open”. IP spoofing sends replies to the spoofed host, so it breaks two-way sessions.

Module 04 — Enumeration

A. High-Yield Concepts

- Extracting usernames, shares, groups, policies, services from discovered hosts.
- Protocol-specific enumeration: NetBIOS, SMB, SNMP, LDAP, NTP, SMTP, DNS, RPC, NFS. ## B. Must-Know Definitions
- **Enumeration**: active extraction of detailed resource/account info after scanning.
- **Null session**: unauthenticated connection to IPC\$ to enumerate (legacy SMB).
- **MIB/OID**: SNMP database / individual managed object. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Scanning | Enumeration | Find hosts/ports vs extract users/shares | | SNMP public | SNMP private | Read-only vs read-write community string | | LDAP | LDAPS | 389 cleartext vs 636 TLS | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | enum4linux | SMB/NetBIOS enumeration | 04 | Full Windows enum | | nbtstat / nbtscan | NetBIOS names | 04 | -A <IP> | | snmpwalk | SNMP enumeration | 04 | Community strings | | ldapsearch | LDAP/AD enumeration | 04 |

- Directory objects | | rpcinfo / showmount | RPC / NFS exports | 04 | showmount -e | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—| | SNMP default strings | Network devices | Config disclosure | SNMPv3, change strings | | SMTP VRFY/EXPN | Mail server | Valid user harvest | Disable VRFY/EXPN | | Zone transfer | DNS | Full record dump | Restrict AXFR | ## F. Methodology / Sequence Identify service/port → connect → extract (users/shares/policies) → map to attack surface. ## G. High-Value Facts
- Ports: NetBIOS 137-139, SMB 445, SNMP 161/162, LDAP 389/636, SMTP 25, RPC 111/135, NFS 2049, Global Catalog 3268, Kerberos 88.
 - NetBIOS codes: <00> workstation, <20> file server, <1C> domain controllers, <1B> domain master browser.
 - SMTP: **VRFY** (verify user), **EXPN** (expand list), **RCPT TO** (recipient check). ## H. Exam Traps
- Watch:** public =read-only, private =read-write (SNMP). SNMPv1/v2c weak, v3 secure. IPC\$ is the null-session share. net view lists shares; nbtstat -A queries by IP.

Module 05 — Vulnerability Analysis

A. High-Yield Concepts

- Vulnerability management lifecycle; scan types; scoring/identification standards.
- Credentialed vs non-credentialed; false positives/negatives. ## B. Must-Know Definitions
- **CVE**: unique vulnerability identifier (MITRE). **CVSS**: severity score 0-10 (FIRST). **CWE**: weakness type (MITRE). **CPE**: product identifier (NIST).
- **False positive**: reported but not real. **False negative**: real but missed (dangerous). ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | CVE | CVSS | Identifier vs severity score | | Credentialed | Non-credentialed | Logged-in depth vs outside view | | False positive | False negative | Wrong alarm vs missed real vuln | | Remediation | Mitigation | Remove vuln vs reduce risk | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Nessus / OpenVAS | Vuln scanning | 05 | General/host | | Qualys / InsightVM | Enterprise VM | 05 | Risk-based | | Nikto | Web server scan | 05 | Web-specific | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Exploit unpatched CVE | Host/app | Compromise | Patch management | | Default creds | Device | Easy access | Change defaults | ## F. Methodology / Sequence Lifecycle: identify assets → assess/scan → prioritize (CVSS) → remediate/mitigate → verify → monitor (continuous). ## G. High-Value Facts
- CVSS bands: 0 None · 0.1-3.9 Low · 4.0-6.9 Medium · 7.0-8.9 High · 9.0-10 Critical.
- Scan types: active/passive, internal/external, agent-based/agentless.
- **NVD** (NIST) aggregates CVE+CVSS+CWE+CPE; **Exploit-DB** via searchsploit. ## H. Exam Traps

Watch: CVE ≠ CVSS. Credentialed scans are more accurate (internal view). False negatives are the dangerous ones. Remediation removes; mitigation only reduces.

Module 06 — System Hacking

A. High-Yield Concepts

- Gain access → escalate → execute → hide → maintain → cover tracks.
- Password attacks; Windows/Linux credential storage; Kerberos; privilege escalation; steganography; log clearing. ## B. Must-Know Definitions
- **Pass-the-Hash**: authenticate with an NTLM hash (no plaintext). **Pass-the-Ticket**: reuse a Kerberos ticket.
- **Golden ticket**: forged TGT (krbtgt hash) = whole domain. **Silver ticket**: forged service ticket = one service.
- **Steganography**: hide the existence of data; **cryptography**: hide its meaning. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Vertical privesc | Horizontal privesc | Higher privilege vs same-level other user | | Pass-the-Hash | Pass-the-Ticket | NTLM hash vs Kerberos ticket | | Golden ticket | Silver ticket | Whole domain (TGT) vs one service | | Steganography | Cryptography | Hide existence vs hide meaning | | Online attack | Offline attack | Against login service vs captured hashes | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Mimikatz | Credential dumping | 06 | PtH, golden ticket | | John / Hashcat | Offline cracking | 06 | CPU / GPU | | Hydra / Medusa | Online cracking | 06 | Login services | | Responder | LLMNR/NBT-NS poison | 06 | Hash capture | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Pass-the-Hash | NTLM auth | Lateral movement | Credential Guard, LAPS | | LSASS dump | Memory creds | Harvest hashes/tickets | Protected process, EDR | | Rainbow table | Hashes | Fast crack | Salting | ## F. Methodology / Sequence Gain access → crack passwords → escalate privileges → execute apps → hide files → maintain persistence → cover tracks. ## G. High-Value Facts
- **SAM**: C:\Windows\System32\config\SAM (local NTLM). **NTDS.dit**: AD hashes on DC. **LSASS**: creds in memory.
- Linux hashes in `/etc/shadow` (not `/etc/passwd`). Linux logs in `/var/log`.
- **LM** weakness: uppercased, split into two 7-char halves, no salt.
- Kerberos parts: Client, **KDC**, **TGT**, service ticket. ## H. Exam Traps

Watch: Hashes are in `/etc/shadow`, not `/etc/passwd`. Hardware keyloggers evade AV (not software). “DLL=Windows, PATH=Linux” is a mnemonic — Windows also has PATH/search-order hijacking.

Module 07 — Malware Threats

A. High-Yield Concepts

- Malware types and components; delivery methods; trojans/viruses/worms; ransomware; rootkits; botnets; fileless; APT; malware analysis. ## B. Must-Know Definitions
- **Virus**: replicates into a host/file. **Worm**: self-propagates autonomously. **Trojan**: disguised, no self-replication.
- **Dropper** delivers malware; **Downloader** fetches more; **Crypter/Packer** evade AV; **Payload** does the harm.

- **APT:** stealthy, long-term, targeted campaign (not one malware family). ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Virus | Worm | Needs host vs self-propagating | | Worm | Trojan | Self-replicates vs disguised delivery | | Static analysis | Dynamic analysis | Inspect w/o running vs run in sandbox | | Overt channel | Covert channel | Intended comms vs hidden exfil path | | Crypto ransomware | Locker ransomware | Encrypt files vs lock device | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | VirusTotal | Multi-engine scan | 07 | Hash/file lookup | | IDA / Ghidra | Disassembly | 07 | Static analysis | | Cuckoo / Any.Run | Sandbox | 07 | Dynamic analysis | | PEiD / Detect It Easy | Packer detection | 07 | Static | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Ransomware | Files | Encryption + extortion | Offline/immutable backups (3-2-1) | | Fileless (LOLBins) | Memory | Evade AV | EDR, script-block logging | | Rootkit | Kernel/boot | Hide presence | Secure Boot, integrity checks | ## F. Methodology / Sequence Malware lifecycle: **Delivery → Execution → Installation → Persistence → C2 → Actions on objectives.** ## G. High-Value Facts
- Ransomware crypto: **AES** encrypts files, **RSA/ECC** encrypts the AES key (hybrid).
- Rootkit types: user-mode, kernel-mode, bootkit, firmware, hypervisor.
- Sheep dip = isolated analysis machine. 3-2-1 backups: 3 copies, 2 media, 1 offline. ## H. Exam Traps

Watch: Only virus & worm self-replicate; trojan does not. PUA ≠ confirmed malware. Fileless ≠ “just RAM” — it abuses trusted tools (LOLBins). APT is a campaign, not a file.

Module 08 — Sniffing

A. High-Yield Concepts

- Passive vs active sniffing; MAC flooding; ARP spoofing; DHCP attacks; DNS poisoning; sniffing tools/defenses. ## B. Must-Know Definitions
- **Promiscuous mode:** NIC accepts all frames. **SPAN/port mirroring:** switch copies traffic to a monitor port.
- **ARP spoofing:** forged ARP replies poison caches → MITM. **MAC flooding:** overflow CAM table → switch fails open. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Passive sniffing | Active sniffing | Hub/listen vs switch/inject | | ARP (host) | CAM table (switch) | IP→MAC vs MAC→port | | MAC flooding | ARP spoofing | CAM overflow vs cache poisoning | | DNS spoofing | DNS cache poisoning | Fake reply vs stored fake record | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Wireshark | GUI packet analysis | 08 | Display filters | | tcpdump / tshark | CLI capture | 08 | Headless | | Ettercap / Bettercap | MITM framework | 08 | ARP spoof | | macof | MAC flooding | 08 | CAM overflow | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | ARP spoofing | LAN hosts | MITM | Dynamic ARP Inspection | | MAC flooding | Switch CAM | Traffic flooding/capture | Port security, sticky MAC | | Rogue DHCP | Clients | Fake gateway/DNS | DHCP snooping | ## F. Methodology / Sequence Gain LAN position → poison (ARP/CAM/DHCP) → capture → analyze/extract credentials. ## G. High-Value Facts
- Wireshark filters: `ip.addr== , tcp.port==80 , http , tcp.flags.syn==1 .`
- DHCP = DORA (Discover, Offer, Request, Ack); server UDP 67, client 68.
- Layer-2 defenses: **DAI, DHCP snooping, port security, 802.1X.** ## H. Exam Traps

Watch: CAM table (switch, MAC→port) vs ARP cache (host, IP→MAC). Capture filter (BPF) limits recording; display filter only hides. ARP has no authentication — that's why spoofing works.

Module 09 — Social Engineering

A. High-Yield Concepts

- Human/computer/mobile-based SE; phishing family; psychological triggers; insider threats; defenses. ## B. Must-Know Definitions
- **Pretexting:** fabricated scenario. **Impersonation:** fake identity. **Tailgating:** follow without permission. **Piggybacking:** enter with permission/awareness.
- **Vishing** (voice), **Smishing** (SMS), **Whaling** (executives), **BEC** (business email compromise). ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Tailgating | Piggybacking | No permission vs permitted/aware | | Impersonation | Pretexting | Fake identity vs fake story | | Phishing | Spear phishing | Mass vs targeted | | Phishing | Whaling | General vs executive target | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | SET | SE framework | 09 | Cloning, harvesting | | Gophish / King Phisher | Phishing campaigns | 09 | Simulation | | Evilginx / Modlishka | Reverse-proxy phishing | 09 | MFA bypass | | Maltego / theHarvester | OSINT | 09 | Target profiling | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Phishing | Users | Credential theft | Awareness, DMARC, MFA | | Tailgating | Facility | Physical entry | Mantraps, badges | | Deepfake/vishing | Staff | Fraud/authorization | Multi-channel verification | ## F. Methodology / Sequence Research target → select target → develop relationship → exploit relationship. ## G. High-Value Facts
- Triggers: **authority, intimidation, consensus, scarcity, urgency, familiarity, trust, greed.**
- Email auth: **SPF, DKIM, DMARC.**
- Authentication factors: know / have / are. ## H. Exam Traps

Watch: Tailgating (no permission) vs piggybacking (with permission). Whaling targets executives; BEC impersonates them. Reverse SE = victim contacts the attacker.

Module 10 — Denial-of-Service

A. High-Yield Concepts

- DoS vs DDoS; volumetric/protocol/application attacks; reflection & amplification; botnets; detection; mitigation. ## B. Must-Know Definitions
- **DoS:** disrupt availability from one source. **DDoS:** distributed sources (botnet).
- **Reflection:** spoof victim IP so 3rd-party servers reply to victim. **Amplification:** response >> request.
- **Phlashing (PDoS):** permanent damage/bricking (e.g., malicious firmware). ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | DoS | DDoS | Single source vs distributed | | Reflection | Amplification | 3rd-party responder vs response multiplication | | SYN flood | UDP flood | Half-open TCP vs UDP volume | | Blackholing | Sinkholing | Drop all vs redirect for analysis | ## D. Tool Recognition | Tool | Purpose | Module

| CEH Association | |—|—|—|—| | LOIC / HOIC | Flooding | 10 | Classic DDoS | | hping3 | Packet flood/craft | 10 | SYN flood | | Mirai (botnet) | IoT DDoS | 10 | Default-cred infection | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | SYN flood | Connection table | Exhaust half-open | SYN cookies, rate limit | | DNS/NTP amplification | Bandwidth | Massive volume | Disable open resolvers, BCP38 | | Slowloris | Web server threads | Hold connections | Timeouts, reverse proxy/WAF | ## F. Methodology / Sequence Build/rent botnet → deliver bot → C2 coordinates → launch flood → sustain/evade. ## G. High-Value Facts

- Categories: **volumetric** (UDP/ICMP/DNS amp), **protocol** (SYN, Smurf, teardrop, LAND), **application** (HTTP flood, Slowloris).
- Amplifiers: **DNS, NTP, SSDP, Memcached, CLDAP**.
- Metrics: PPS, BPS, RPS. ## H. Exam Traps

Watch: DoS vs DDoS = source distribution. A single attack can be both reflective and amplifying. Phlashing = permanent (bricking), not just downtime. Smurf = ICMP, Fraggle = UDP.

Module 11 — Session Hijacking

A. High-Yield Concepts

- Session vs session ID; cookie attributes; hijacking types; TCP hijacking; sequence numbers; defenses. ## B. Must-Know Definitions
- **Session hijacking:** taking over an established session. **Session fixation:** force victim to use a known session ID before login.
- **Spoofing:** impersonate a source; **hijacking:** take over an existing session (not synonyms). ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Spoofing | Session hijacking | Impersonate vs take over active session | | Session fixation | Session hijacking | Preset ID before login vs steal active | | Network-level | Application-level | TCP/UDP session vs HTTP session ID | | Blind | Non-blind | Guess sequence numbers vs observe traffic | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Burp Suite | Web session testing | 11 | Cookie analysis | | Ettercap / Bettercap | MITM | 11 | Token capture | | Wireshark | Traffic analysis | 11 | Sequence numbers | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Cookie theft (XSS) | Session ID | Account takeover | HttpOnly, Secure, SameSite | | Session fixation | Session ID | Known-ID hijack | Regenerate ID after login | | TCP hijack | Active session | Inject commands | Encryption (TLS/SSH) | ## F. Methodology / Sequence Track the connection → desynchronize → inject packets/commands. ## G. High-Value Facts
- Cookie attributes: **Secure** (HTTPS only), **HttpOnly** (no JS access), **SameSite** (CSRF help).
- TCP hijack needs valid **sequence numbers** within the **window**.
- Defenses: HTTPS, token rotation, session timeout, MFA. ## H. Exam Traps

Watch: Fixation sets the ID before login; hijacking steals an active one. Spoofing ≠ hijacking. Regenerating the session ID after login defeats fixation.

Module 12 — Evading IDS, Firewalls & Honeypots

A. High-Yield Concepts

- IDS vs IPS; NIDS vs HIDS; detection methods; firewall types; evasion; tunneling; honeypots. ## B. Must-Know Definitions
- **IDS**: detects & alerts (passive). **IPS**: inline, detects & blocks.
- **Honeypot**: decoy to attract/study attackers. **Bastion host**: hardened public-facing system. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | IDS | IPS | Alert vs inline block | | NIDS | HIDS | Network traffic vs single host | | Signature | Anomaly detection | Known patterns vs behavioral deviation | | True/False Positive | True/False Negative | Alert fired vs attack missed | | Stateful | Stateless firewall | Tracks connections vs per-packet | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Snort / Suricata | IDS/IPS | 12 | Rule signatures | | Nmap -f -D | Evasion | 12 | Fragment/decoy | | Nessus | Firewall/vuln checks | 12 | Assessment | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Packet fragmentation | IDS | Evade signatures | Reassembly, modern IPS | | HTTP/DNS/ICMP tunneling | Firewall | Bypass filtering | DPI, egress filtering | | Decoy scan | Attribution | Hide source | Correlation | ## F. Methodology / Sequence Identify controls (firewalking, banner) → choose evasion (fragment/decoy/tunnel/encrypt) → test → exploit. ## G. High-Value Facts
- Alert matrix: TP (attack+alert), FP (no attack+alert), FN (attack+no alert), TN (none+none).
- Detection: **signature, anomaly, protocol-anomaly**.
- Firewall types: packet-filter, stateful, circuit-level, application/proxy, NGFW. ## H. Exam Traps

Watch: IDS detects, IPS blocks (inline). NIDS=network, HIDS=host. Honeypot attracts attackers; IDS monitors production. Signature can't catch zero-days; anomaly has more false positives.

Module 13 — Hacking Web Servers

A. High-Yield Concepts

- Web server architecture/components; misconfiguration; specific server attacks; hardening. ## B. Must-Know Definitions
- **Document root** (web files) vs **server root** (config/binaries). **Directory traversal**: `../` to escape web root.
- **Web cache poisoning, HTTP response splitting, web defacement, SSRF**. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Web server | Web application | Serves content/HTTP vs business logic | | Document root | Server root | Site files vs config/executables | | Directory traversal | LFI | Read files vs include/execute files | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Nikto | Web server scanner | 13 | Misconfig/CVEs | | Nmap http-* NSE | Server fingerprint | 13 | Headers | | Gobuster/DirBuster | Dir/file brute | 13 | Hidden content | | Hydra | Web login crack | 13 | Online attack | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Directory traversal | Filesystem | Read sensitive files | Input validation, chroot | | Misconfiguration | Server | Info disclosure | Hardening, patch | | DNS server hijacking | Resolution | Redirect users | DNSSEC, monitoring | ## F. Methodology /

Sequence Footprint server → fingerprint/banner → scan vulns → exploit → escalate → maintain → cover tracks. ## G. High-Value Facts

- Banner grabbing: Server: , X-Powered-By: headers; curl -I , Nmap, Whatweb.
- Apache = modular (mod_ssl, mod_rewrite, mod_proxy); IIS on Windows.
- Hardening: patch, disable directory listing, hide banners, least privilege, WAF. ## H. Exam Traps

Watch: Web server (HTTP/content) vs web application (logic). Directory traversal reads files; LFI/RFI includes/executes. SSRF makes the server send requests (e.g., cloud metadata).

Module 14 — Hacking Web Applications

A. High-Yield Concepts

- Web app architecture; OWASP Top 10 (2021); injection, XSS, CSRF, SSRF, IDOR, file inclusion; web services; methodology/tools. ## B. Must-Know Definitions
- **XSS**: inject script that runs in a victim's browser. **CSRF**: force a logged-in victim's browser to send an unwanted request.
- **SSRF**: make the server issue attacker-chosen requests. **IDOR**: change an object reference to access others' data. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | XSS | CSRF | Script in browser vs forced request | | Stored XSS | Reflected XSS | Saved on server vs echoed from request | | SSRF | CSRF | Server makes request vs victim's browser does | | LFI | RFI | Local file vs remote file inclusion | | Authentication | Authorization failure | Identity vs access-control flaw (IDOR) | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Burp Suite | Intercepting proxy | 14 | All-purpose | | OWASP ZAP | Proxy/scanner | 14 | Open-source | | sqlmap | SQLi automation | 14/15 | Injection | | BeEF | Browser exploitation | 14 | XSS hooking | | ffuf / wfuzz | Fuzzing | 14 | Parameter/dir | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Stored XSS | Users | Cookie theft/BeEF | Output encoding, CSP, HttpOnly | | CSRF | Authenticated action | Unwanted action | CSRF tokens, SameSite | | SSRF | Internal services | Metadata/creds theft | Allow-list, block internal ranges | | IDOR | Objects | Data exposure | Enforce authorization per object | ## F. Methodology / Sequence Footprint infra → analyze app → bypass client-side controls → attack auth → auth-z → session → input validation → logic → DB. ## G. High-Value Facts
- OWASP 2021: A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, A04 Insecure Design, A05 Security Misconfig, A06 Vulnerable Components, A07 Auth Failures, A08 Software/Data Integrity, A09 Logging/Monitoring Failures, A10 SSRF.
- Web services: **SOAP** (XML protocol), **REST** (style/JSON), **WSDL** (describe), **UDDI** (registry), **WS-Security**.
- Client-side validation is bypassable — enforce server-side. ## H. Exam Traps

Watch: XSS runs in the browser (trust of site in user... reversed); CSRF abuses the site's trust in the user. SSRF = server-side; CSRF = client-side. A01 is now Broken Access Control (top risk).

Module 15 — SQL Injection

A. High-Yield Concepts

- SQLi concept; in-band / blind / out-of-band; error/UNION/boolean/time; detection; evasion; countermeasures. ## B. Must-Know Definitions
- **SQLi**: input treated as query structure (data-as-code). **Tautology**: ' OR '1'='1.
- **Blind SQLi**: no data returned; infer via boolean or timing. **Second-order**: stored payload executes later. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | In-band | Out-of-band | Same channel vs separate (DNS/HTTP) | | Error-based | UNION-based | Leak via errors vs append rows | | Boolean blind | Time-based blind | True/false page vs response delay | | Blind SQLi | In-band SQLi | Inferred vs directly returned | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | sqlmap | Automated SQLi | 15 | --dbs --dump | | Burp Suite | Manual/intruder | 15 | Fuzzing | | Havij | Legacy GUI SQLi | 15 | Recognition | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Auth bypass | Login query | Access w/o creds | Parameterized queries | | UNION extraction | Database | Dump tables | Input validation, least priv | | Time-based blind | Database | Infer data | Prepared statements, WAF (supplemental) | ## F. Methodology / Sequence Identify input → detect SQLi → determine DBMS → enumerate schema (DBs→tables→columns) → extract → escalate (file/OS). ## G. High-Value Facts
- **Parameterized/prepared statements** = best defense (data ≠ code).
- Fingerprint: @@version, information_schema, comment styles --, #, /**/.
- Evasion: case toggling, inline comments, encoding, whitespace. ## H. Exam Traps

Watch: WAF is supplemental, not the fix — parameterized queries are. Blind SQLi returns no data (boolean vs time). Error-based needs visible errors; disable verbose DB errors.

Module 16 — Hacking Wireless Networks

A. High-Yield Concepts

- 802.11 standards/bands; WEP/WPA/WPA2/WPA3; authentication (PSK vs Enterprise); wireless attacks; Bluetooth; tools; methodology; defenses. ## B. Must-Know Definitions
- **Rogue AP**: unauthorized AP on the network. **Evil twin**: fake AP mimicking a legit SSID.
- **Association** (connect to AP) vs **authentication** (verify client). **WPS**: PIN-based setup, brute-forceable. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | WEP | WPA2 | RC4/24-bit IV (broken) vs AES-CCMP | | WPA2 | WPA3 | AES-CCMP/PSK vs SAE (offline-resistant) | | Personal (PSK) | Enterprise (802.1X) | Shared key vs RADIUS/EAP per-user | | Rogue AP | Evil twin | Unauthorized AP vs impersonating SSID | | Association | Authentication | Connect vs verify identity | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | Aircrack-ng suite | Capture/crack | 16 | airodump/aireplay | | Reaver / Bully | WPS PIN attack | 16 | wash discovery | | Kismet | Detection | 16 | Rogue AP | | Wifiphisher / Fern | Evil twin | 16 | Rogue portal | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Deauth | Clients | Force reconnect/handshake | WPA3/802.11w (PMF) | | Evil twin | Clients | Credential capture/MITM | WIDS/WIPS, 802.1X | | WPS PIN brute | AP | Recover PSK | Disable WPS | ## F.

Methodology / Sequence Wi-Fi discovery → GPS mapping → traffic analysis → deauth → capture handshake → crack key → compromise. ## G. High-Value Facts

- Bands: 2.4 GHz (range) / 5 GHz (speed); 802.11ax (Wi-Fi 6) also 6 GHz.
- WEP = RC4 + **24-bit IV** + CRC-32 (broken). WPA3-Personal = **SAE**.
- Bluetooth: **Bluejacking** (send), **Bluesnarfing** (steal), **Bluebugging** (control), **Bluesmacking** (DoS). ## H. Exam Traps

Watch: Rogue AP (unauthorized) vs evil twin (impersonates SSID). Association ≠ authentication. MAC filtering is weak (MACs are spoofable). WEP's core flaw = 24-bit IV reuse.

Module 17 — Hacking Mobile Platforms

A. High-Yield Concepts

- Mobile attack surface (device/network/data center); Android vs iOS; rooting/jailbreaking; app-store risks; sandboxing; MDM; defenses. ## B. Must-Know Definitions
- **Rooting** (Android) / **Jailbreaking** (iOS): remove OS restrictions to gain privileged control.
- **MDM**: central device policy/remote wipe. **Containerization**: separate work/personal data. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Rooting | Jailbreaking | Android vs iOS privilege removal | | APK | IPA | Android vs iOS app package | | MDM | MAM | Device management vs app management | | Tethered | Untethered jailbreak | Needs PC each boot vs persists | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | ADB | Android device control | 17 | Debug bridge | | MobSF | App static/dynamic analysis | 17 | APK/IPA | | Drozer | Android attack surface | 17 | IPC testing | | apktool | Decompile/rebuild APK | 17 | Reverse | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Malicious/repackaged app | Device | Data theft | Official stores, vetting | | Rogue AP / SSLStrip | Mobile traffic | MITM | VPN, cert pinning | | Smishing | User | Credential/malware | Awareness, filtering | ## F. Methodology / Sequence Mobile attack chain: **device → network → data center/cloud** (a compromise can traverse all three). ## G. High-Value Facts
- OWASP Mobile themes: insecure data storage, insecure comms, improper credential use, insufficient binary protection.
- Android stack: Apps → Framework → Libraries+ART → Linux kernel.
- Jailbreak types: tethered, semi-tethered, untethered, semi-untethered. ## H. Exam Traps

Watch: Rooting=Android, jailbreaking=iOS. Sandbox escape magnifies a malicious app. Third-party app stores and excessive permissions are key risks.

Module 18 — IoT and OT Hacking

A. High-Yield Concepts

- IoT architecture, protocols, communication models; OWASP IoT Top 10; OT/ICS/SCADA; attack surfaces; defenses. ## B. Must-Know Definitions
- **IoT**: networked smart devices with sensors. **OT**: tech controlling physical/industrial processes.

- **SCADA/ICS/PLC/HMI/RTU/DCS**: industrial control components. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | IoT | OT | Consumer/networked devices vs industrial control | | Cloud | Fog / Edge | Central vs near-/at-device processing | | MQTT | CoAP | Pub/sub broker vs constrained REST | | IT security | OT security | CIA priority vs **availability/safety** first | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—| | Shodan | Find exposed devices | 18 | IoT/ICS discovery | | Binwalk / Firmwalker | Firmware analysis | 18 | Extraction | | Wireshark | Protocol analysis | 18 | Modbus/MQTT | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—| | Default creds (Mirai) | IoT devices | Botnet/DDoS | Change defaults, segmentation | | Firmware tampering | Device | Persistent control | Signed updates, secure boot | | ICS protocol abuse | SCADA/PLC | Process disruption | IT/OT segmentation, IEC 62443 | ## F. Methodology / Sequence IoT hacking: information gathering → vulnerability scanning → launch attacks → gain access → maintain access. ## G. High-Value Facts
- IoT comm models: device-to-device, device-to-cloud, device-to-gateway, back-end data-sharing.
- OWASP IoT #1 = **Weak, Guessable, or Hardcoded Passwords**.
- OT protocols (Modbus, DNP3, PROFINET) often lack auth/encryption. **Stuxnet** targeted PLCs.
- **Purdue model** levels 0-5 for ICS. ## H. Exam Traps

Watch: OT prioritizes availability/safety over confidentiality. Air-gap/segmentation is the key OT control. Mirai spread via default credentials. IoT #1 risk = weak/hardcoded passwords.

Module 19 — Cloud Computing

A. High-Yield Concepts

- Service models (IaaS/PaaS/SaaS); deployment models; actors; shared responsibility; containers/serverless/Kubernetes; cloud attacks; controls. ## B. Must-Know Definitions
- **IaaS/PaaS/SaaS**: customer manages most→least infrastructure.
- **Shared Responsibility**: provider secures “of the cloud”; customer “in the cloud” (data/config/identity).
- **Wrapping attack**: tamper a SOAP message so a malicious request is processed as legitimate. **MITC**: steal sync tokens to hijack cloud account. ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | IaaS | SaaS | Customer manages most vs just uses it | | VM | Container | Full OS/hypervisor vs shared kernel | | Public | Private cloud | Shared multi-tenant vs single org | | Wrapping | MITC attack | SOAP message tamper vs token theft | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—| | ScoutSuite / Prowler | Cloud posture audit | 19 | Misconfig | | Pacu | AWS exploitation | 19 | Offensive | | Trufflehog | Secret scanning | 19 | Leaked keys | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—| | Misconfiguration | Storage (S3) | Data exposure | CSPM, block public by default | | SSRF → metadata | IAM creds | Credential theft | Block 169.254.169.254, IMDSv2 | | Side-channel | Co-tenant VM | Data inference | Isolation, dedicated hosts | ## F. Methodology / Sequence Recon cloud assets → find misconfig/exposed services → exploit (SSRF/creds) → escalate IAM → persist. ## G. High-Value Facts
- Deployment: public, private, hybrid, community, multi-cloud.
- Actors: consumer, provider, carrier, auditor, broker.

- Responsibility shifts by model; customer always owns data/identity/config. ## H. Exam Traps

Watch: Responsibility varies by IaaS/PaaS/SaaS. Misconfiguration (public buckets) is the top cloud cause. VM=hypervisor/full OS; container=shared kernel. Metadata SSRF steals cloud IAM creds.

Module 20 — Cryptography

A. High-Yield Concepts

- Symmetric vs asymmetric; block vs stream; algorithms + key sizes; hashing; PKI/certificates/signatures; applications; cryptanalysis & attacks; blockchain; quantum. ## B. Must-Know Definitions
- **Symmetric:** one shared key (fast). **Asymmetric:** public/private pair (solves key distribution).
- **Digital signature:** sign with **private** key, verify with **public** key → integrity+authentication+non-repudiation.
- **PKI roles:** CA (issues), RA (verifies identity), VA (validates status). ## C. Commonly Confused Concepts | Concept A | Concept B | Key Difference | |—|—|—| | Symmetric | Asymmetric | Shared key vs key pair | | Block | Stream cipher | Fixed blocks (AES) vs bit/byte (RC4) | | Hashing | Encryption | One-way vs reversible | | Digital certificate | Digital signature | Identity/key binding vs private-key proof | | CA-signed | Self-signed | Trusted chain vs no third-party trust | | Confidentiality use | Signature use | Recipient's public key vs sender's private key | ## D. Tool Recognition | Tool | Purpose | Module | CEH Association | |—|—|—|—| | VeraCrypt / BitLocker | Disk encryption | 20 | At-rest | | GPG / PGP | File/email encryption | 20 | Hybrid | | OpenSSL | Crypto toolkit/certs | 20 | TLS | | Hashcat / John | Hash cracking (audit) | 20 | GPU/CPU | ## E. Attack → Target → Effect → Defense | Attack | Target | Effect | Important Defense | |—|—|—|—| | Birthday attack | Hash function | Collision | SHA-256+, long digests | | Rainbow table | Unsalted hashes | Fast crack | Salt + slow hash (bcrypt/Argon2) | | POODLE/ DROWN/FREAK | SSL/TLS | Downgrade/decrypt | TLS 1.2/1.3, disable legacy | ## F. Methodology / Sequence Hybrid encryption: asymmetric exchanges a symmetric **session key**; symmetric encrypts bulk data (e.g., TLS). ## G. High-Value Facts
- **Symmetric:** DES(56-bit), 3DES(168), **AES(128/192/256, 128-bit block)**, RC4(stream), Blowfish, ChaCha20(stream).
- **Asymmetric:** RSA(factoring), Diffie-Hellman(key exchange), ECC(curves), DSA(signatures).
- **Hashes:** MD5(128, broken), SHA-1(160, deprecated), SHA-256/512, SHA-3.
- Blockchain attacks: **51%, Finney, Eclipse, Race, DeFi sandwich**. Quantum: **Shor** (breaks RSA/ECC), **Grover** (halves symmetric); **harvest-now-decrypt-later**. ## H. Exam Traps

Watch: Sign = private key; verify = public key. Encrypt for confidentiality = recipient's PUBLIC key. Hashing ≠ encryption (one-way). AES=block, RC4/ChaCha20=stream. HMAC gives integrity+auth, NOT non-repudiation.

Scoring Benchmark & Self-Review

Study benchmark only — NOT the official EC-Council passing score (the real cut score is set per exam form, ~60–85%).

Score (of 125)	Interpretation
106-125	Target range ($\geq 85\%$)
100-105	Close; revise weak areas
94-99	Below target; revision required
< 94	Major revision required

After each mock, tally wrong answers by module. Any module with ≥ 3 misses $\rightarrow$ revisit that module's **H. Exam Traps** + **C. Confused Concepts** here, then redo those question types. Don't reread whole modules; drill the gaps.

21-Day CEH Practice Plan

~2 hrs/day. Practice-driven, not lecture-driven.

Day	Focus (≈ 2 hrs)
1	Guide M01-M03 + do 20 MCQs on those modules
2	Guide M04-M05 + 20 MCQs; review every wrong answer
3	Guide M06-M07 + 20 MCQs (System/Malware)
4	Guide M08-M10 + 20 MCQs (Sniffing/SE/DoS)
5	Guide M11-M12 + 20 MCQs; redo Day-1 misses
6	Guide M13-M15 + 25 scenario MCQs (web/SQLi)
7	Rest/light: re-read all H. Exam Traps
8	Guide M16 (wireless) deep + 20 MCQs
9	Guide M17-M18 (mobile/IoT/OT) + 20 MCQs
10	Guide M19 (cloud) + 20 MCQs
11	Guide M20 (crypto) deep + 25 MCQs
12	Timed set: 60 mixed MCQs in 115 min
13	Review Day-12 misses; redo those topics
14	MOCK EXAM 1 (125 Q / 4 hrs, timed)
15	Full review of Mock 1; log weak modules
16	Drill 2 weakest modules (traps + confused concepts)
17	Drill next 2 weakest modules; 30 hard MCQs
18	MOCK EXAM 2 (125 Q / 4 hrs, timed)
19	Full review of Mock 2; compare weak areas vs Mock 1
20	Final 72 Hours sheet + redo all previously-missed Qs
21	Last-Minute Rapid Review (30-45 min) + rest before exam

Pacing: 125 Q in 240 min $\approx$ **1 min 55 sec/question**. Flag-and-move after ~90 sec; never leave blanks (no negative marking).

Final 72 Hours Before CEH

Revise only the highest-value material. Do **not** start new topics.

Highest-value to revise - All **H. Exam Traps** and **C. Confused Concepts** tables (this guide).

- Ports & protocols; DNS records; scan types & responses; crypto key sizes/types. - OWASP Top 10 (2021) mapping; SQLi types; wireless encryption ladder.

Terminology traps to lock in - IDS vs IPS · NIDS vs HIDS · DoS vs DDoS · reflection vs amplification. - Spoofing vs hijacking · fixation vs hijacking · XSS vs CSRF vs SSRF · LFI vs RFI. - Rooting vs jailbreaking · IoT vs OT · symmetric vs asymmetric · hashing vs encryption. - CVE vs CVSS · remediation vs mitigation · tailgating vs piggybacking.

High-value tool associations: Nmap, enum4linux, Nessus, Mimikatz, Wireshark, Ettercap, sqlmap, Burp, Aircrack-ng, Reaver, Shodan, Pacu.

Approaching hard MCQs 1. Read the last line first (what's actually asked). 2. Eliminate 2 clearly wrong options. 3. Pick the **best** answer, not merely a correct one (CEH favors "most appropriate"). 4. Watch qualifiers: BEST, MOST, FIRST, LEAST, NOT.

What NOT to spend time on: obscure historical tool version numbers, memorizing full vendor product catalogs, exploit code, niche protocol trivia not in the modules.

Last-Minute Rapid Review (30-45 min)

Ports

FTP 20/21 · SSH 22 · Telnet 23 · SMTP 25 · DNS 53 · DHCP 67/68 · TFTP 69 · HTTP 80 · Kerberos 88 · POP3 110 · RPC 111/135 · NTP 123 · NetBIOS 137-139 · IMAP 143 · SNMP 161/162 · LDAP 389 · HTTPS 443 · SMB 445 · IKE 500 · Syslog 514 · LDAPS 636 · IMAPS 993 · POP3S 995 · MSSQL 1433 · Oracle 1521 · NFS 2049 · MySQL 3306 · RDP 3389 · GC 3268 · PostgreSQL 5432 · VNC 5900. ## Crypto values - Symmetric: DES 56 · 3DES 168 · **AES 128/192/256 (128-bit block)** · RC4/ChaCha20 = stream. - Asymmetric: RSA (factoring), DH (key exchange), ECC (curves), DSA (signatures). - Hash: MD5 128 (broken) · SHA-1 160 (deprecated) · SHA-256/512 · SHA-3. - Sign=private key; verify=public key. Confidentiality=recipient's public key. ## Wireless WEP (RC4/24-bit IV, broken) → WPA (TKIP) → WPA2 (AES-CCMP) → WPA3 (SAE). Disable WPS. PSK vs 802.1X/Enterprise. ## SQLi In-band (error/UNION) · blind (boolean/time) · out-of-band. Fix = **parameterized queries**. ## Web XSS (browser) · CSRF (forced request) · SSRF (server-side) · IDOR (object access). OWASP A01 = Broken Access Control. ## Cloud / Mobile / IoT-OT IaaS→SaaS (less customer infra). Shared responsibility. Misconfig = top cloud risk. Rooting=Android, jailbreak=iOS. IoT #1 = weak/hardcoded passwords. OT = availability/safety first; segment IT/OT. ## Attack names Smurf=ICMP · Fraggle=UDP · LAND=same src/dst · Teardrop=overlapping fragments · Evil twin=fake SSID · Golden=TGT, Silver=service ticket · PtH=NTLM, PtT=Kerberos. ## Exam-trap one-liners IDS detects / IPS blocks · DoS single / DDoS distributed · Tailgating no-permission / Piggybacking with · Steganography hides existence / Cryptography hides meaning · CVE id / CVSS score · Hashing one-way / Encryption reversible. Good luck — read the last line of each question first, eliminate two, choose the BEST.